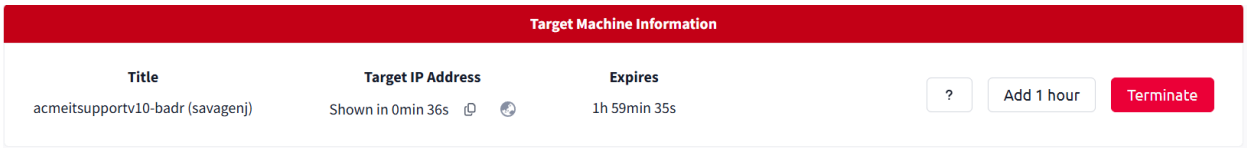
CONTENT DISCOVERY: KHÁM PHÁ NỘI DUNG ẨN TRONG ỨNG DỤNG WEB

Trước hết, trong bối cảnh bảo mật ứng dụng web, chúng ta cần hỏi nội dung là gì? Nội dung có thể là nhiều thứ: một tập tin, video, hình ảnh, bản sao lưu, một tính năng của trang web. Khi nói về việc khám phá nội dung, chúng ta không nói về những thứ hiển nhiên mà chúng ta có thể thấy trên một trang web; đó là những thứ không được hiển thị ngay lập tức và không phải lúc nào cũng được dành cho công chúng truy cập.

Nội dung này có thể là, ví dụ, các trang hoặc cổng thông tin dành cho nhân viên sử dụng, các phiên bản cũ hơn của trang web, các tập tin sao lưu, các tập tin cấu hình, bảng điều khiển quản trị, v.v.

Có ba cách chính để khám phá nội dung trên một trang web mà chúng ta sẽ đề cập đến: Thủ công (manually), Tự động (Automated) và OSINT (Open-Source Intelligence).

Trong bài học này, chúng ta sẽ sử dụng máy ảo được dựng sẵn trên trang web Tryhackme.



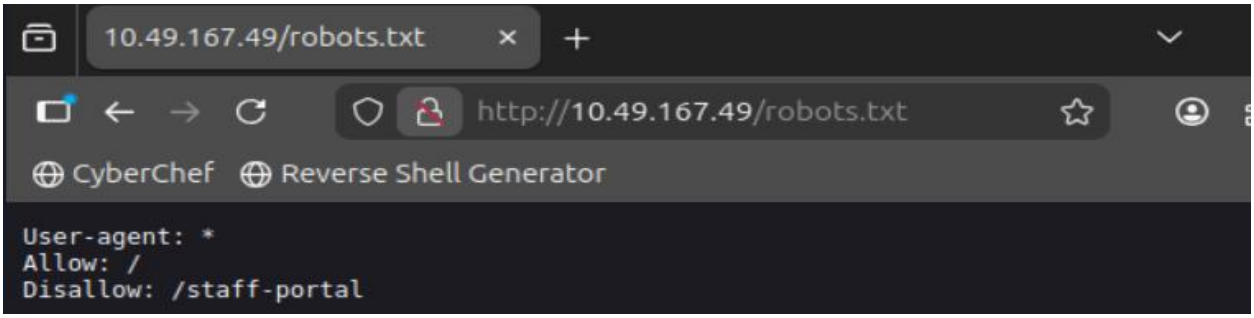
1. Manual Discovery – Robots.txt

Robots.txt

- Tệp robots.txt là một tài liệu cho các công cụ tìm kiếm biết những trang nào chúng được phép và không được phép hiển thị trong kết quả tìm kiếm hoặc cấm hoàn toàn các công cụ tìm kiếm cụ thể thu thập thông tin từ trang web. Những trang này có thể là các khu vực như cổng quản trị hoặc các tệp dành cho khách hàng của trang web. Tệp này cung cấp cho chúng ta một danh sách các vị trí trên trang web mà chủ sở hữu không muốn chúng ta, với tư cách là người kiểm thử xâm nhập, phát hiện ra.

  Take a look at the robots.txt file on the Acme IT Support website to see if they have anything they don't want to list - To do this open Firefox on the AttackBox, and enter the url: http://10.49.167.49/robots.txt (*this URL will update 2 minutes from when you start the machine in task 1*)

- Đề bài yêu cầu chúng ta xem tệp robots.txt trên trang web hỗ trợ CNTT của Acme để xem họ có bất kì thông tin nào không muốn liệt kê hay không.



What is the directory in the robots.txt that isn't allowed to be viewed by web crawlers?

/staff-portal

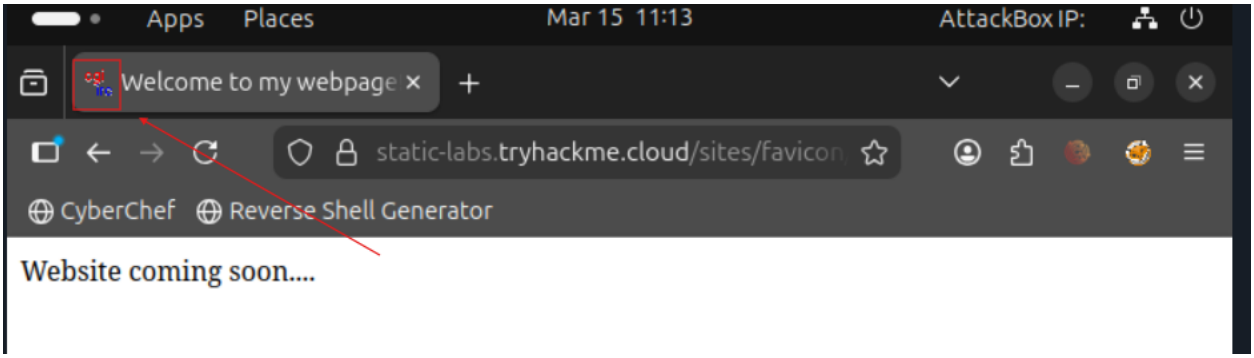
2. Manual Discovery – Favicon

Favicon

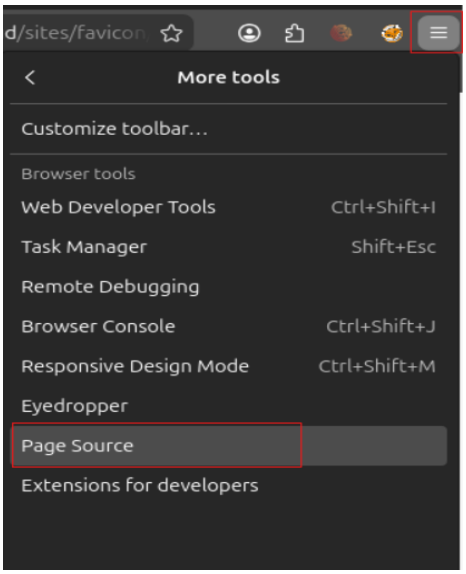
- Favicon là một biểu tượng nhỏ hiển thị trên thanh địa chỉ hoặc tab của trình duyệt, được sử dụng để nhận diện thương hiệu của một trang web.
- Khi sử dụng các framework để xây dựng một trang web, biểu tượng favicon đi kèm với bản cài đặt sẽ bị giữ lại, và nếu nhà phát triển trang web không thay thế nó bằng một biểu tượng tùy chỉnh, điều này có thể cho chúng ta manh mối về framework đang được sử dụng.

Thực hành: Xác định công nghệ framework của website bằng cách phân tích favicon thông qua hash MD5.

Đầu tiên ta truy cập URL theo đề bài cho:



Ta thấy trang web có biểu tượng favicon.
Tiếp theo ta mở "Page source" của trang web lên.



Khi xem mã nguồn, ta sẽ thấy dòng thứ sáu chứa một liên kết đến tệp images/favicon.io

```
1 <!DOCTYPE html>
2
3 <html lang="en">
4 <head>
5     <meta charset="UTF-8">
6     <title>Welcome to my webpage!</title>
7     <link rel="shortcut icon" type="image/jpg" href="images/favicon.ico"/>
8 </head>
9 <body>
10 Website coming soon....
11 <script defer src="https://static.cloudflareinsights.com/beacon.min.js/v8c78df7c7c0f484497ecbca7
12 </body>
13 </html>
```

Nếu ta chạy lệnh sau trên terminal, nó sẽ tải xuống favicon và lấy giá trị băm md5 của nó, sau đó ta có thể tra cứu giá trị này trên https://wiki.owasp.org/index.php/OWASP_favicon_database.

```
root@ip-10-49-120-217:~# curl https://static-labs.tryhackme.cloud/sites/
favicon/images/favicon.ico | md5sum
  % Total    % Received % Xferd  Average Speed   Time    Time     Time
Current
                                 Dload  Upload   Total   Spent    Left
Speed
  0     0    0     0    0     0      0      0 --:--:-- --:--:-- --:--:--
100  1406  100  1406    0     0   3746      0 --:--:-- --:--:-- --:--:--
  3749
f276b19aabcb4ae8cda4d22625c6735f  -
```

Create the page "F276b19aabcb4ae8cda4d22625c6735f" on this wiki! See also the page found with your search.

OWASP favicon database

f276b19aabcb4ae8cda4d22625c6735f:cgiirc (0.5.9)

14 KB (2,567 words) - 23:55, 12 December 2013

Kết quả:

Answer the questions below

What framework did the favicon belong to?

cgiirc

✓ Correct Answer

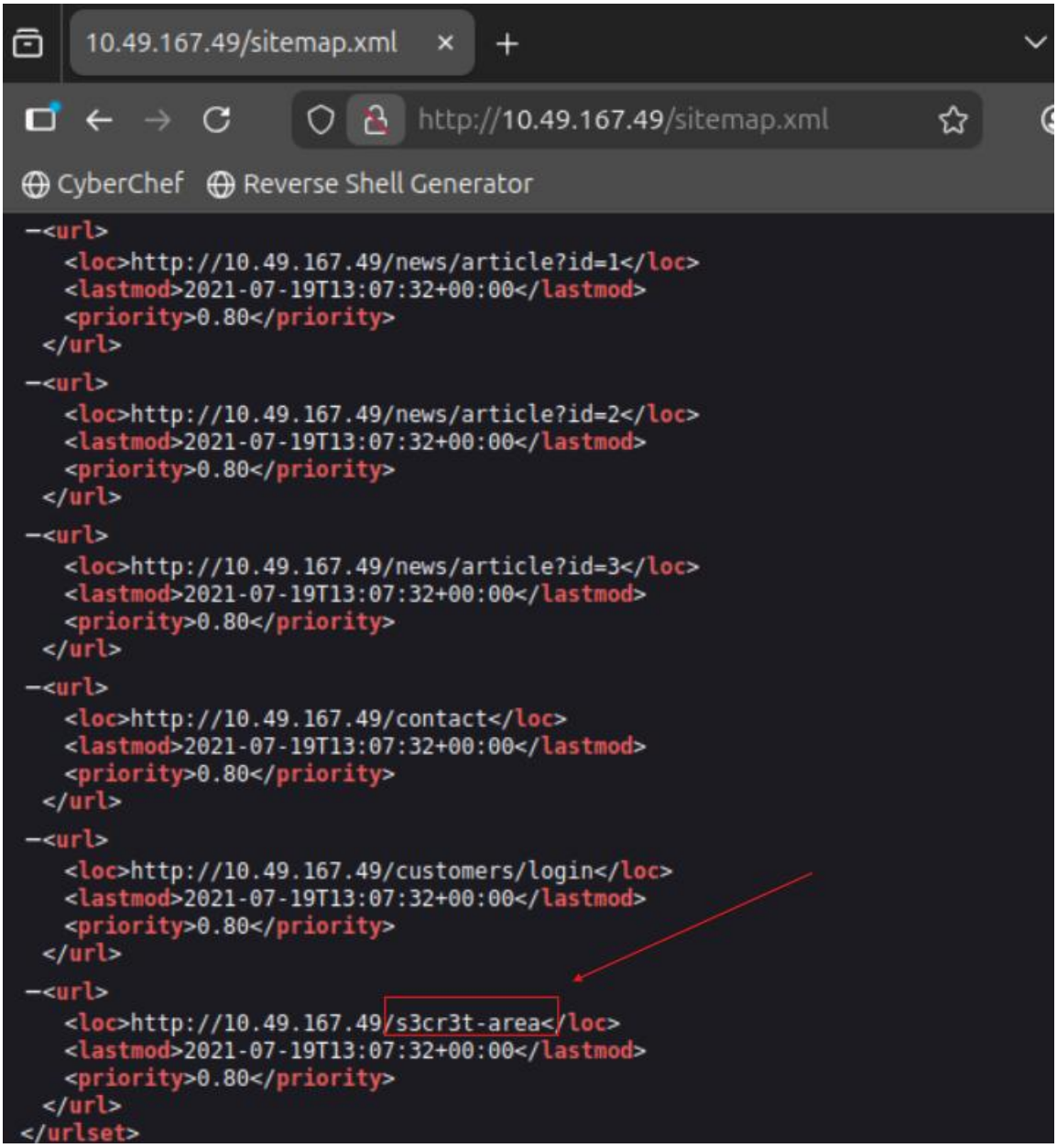
3. Manual Discovery – Sitemap.xml

Sitemap.xml

- Không giống như tệp robots.txt, tệp này giới hạn những gì trình thu thập thông tin của công cụ tìm kiếm có thể xem, tệp sitemap.xml cung cấp danh sách mọi tệp mà chủ sở hữu trang web muốn được hiển thị trên công cụ tìm kiếm. Đôi khi, chúng có thể chứa các khu vực của trang web khó điều hướng hơn hoặc thậm chí liệt kê một số trang web cũ mà trang web hiện tại không còn sử dụng nhưng vẫn hoạt động ngầm.

Take a look at the sitemap.xml file on the Acme IT Support website to see if there's any new content we haven't yet discovered: http://10.49.167.49/sitemap.xml (open this in the FireFox browser on the AttackBox).

- Đề bài yêu cầu xem tệp sitemap.xml trên trang Acme IT Support để xem có nội dung mới nào mà chúng ta chưa phát hiện hay không.



Kết quả:

What is the path of the secret area that can be found in the sitemap.xml file?

/s3cr3t-area ✓ Correct Answer

4. Manual Discovery – HTTP Headers

HTTP Headers

- Khi chúng ta gửi yêu cầu đến máy chủ web, máy chủ sẽ trả về nhiều tiêu đề HTTP khác nhau. Những tiêu đề này đôi khi có thể chứa thông tin hữu ích như phần mềm máy chủ web và có thể cả ngôn ngữ lập trình/scripting đang được sử dụng. Chúng ta chạy lệnh curl dưới đây đối với máy chủ web, trong đó tùy chọn -v cho phép chế độ chi tiết, chế độ này sẽ xuất ra các tiêu đề.

```
root@ip-10-49-120-217:~# curl http://10.49.167.49 -v
*   Trying 10.49.167.49:80...
* Connected to 10.49.167.49 (10.49.167.49) port 80
> GET / HTTP/1.1
> Host: 10.49.167.49
> User-Agent: curl/8.5.0
> Accept: */*
>
< HTTP/1.1 200 OK
< Server: nginx/1.18.0 (Ubuntu)
< Date: Sun, 15 Mar 2026 11:34:52 GMT
< Content-Type: text/html; charset=UTF-8
< Transfer-Encoding: chunked
< Connection: keep-alive
< X-FLAG: THM{HEADER_FLAG}
<
<!--
This page is temporary while we work on the new homepage @ /new-home-bet
a
-->
<!DOCTYPE html>
<html lang="en">
<head>
    <title>Acme IT Support - Home</title>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1">
```

What is the flag value from the X-FLAG header?

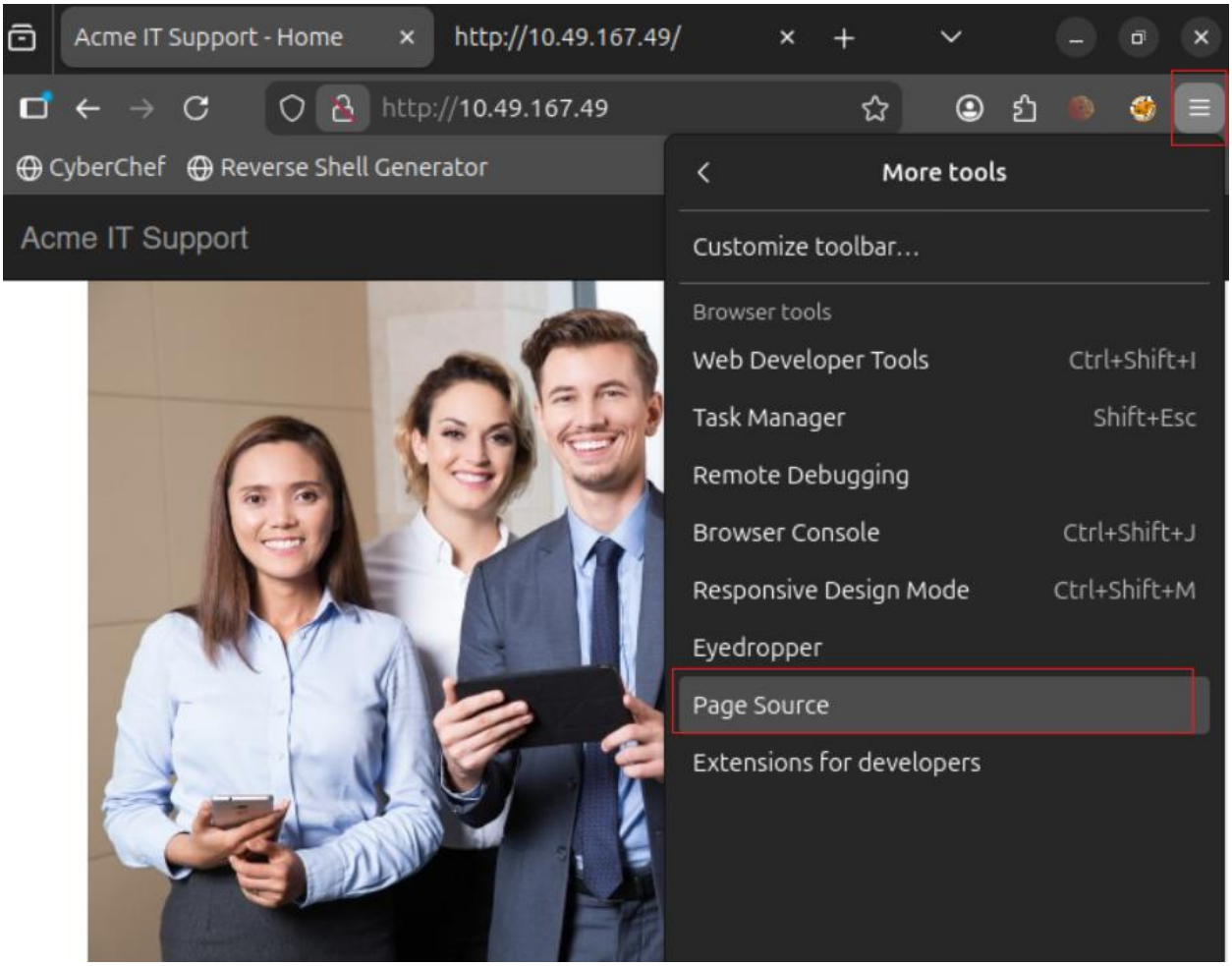
THM{HEADER_FLAG} ✓ Correct Answer

5. Manual Discovery – Framework Stack

Framework Stack

- Khi chúng ta đã xác định được cấu trúc tổng thể của một trang web, bằng cách xem ví dụ favicon ở trên hoặc tìm kiếm manh mối trong mã nguồn trang như bình luận, thông báo bản quyền hoặc thông tin tác giả, chúng ta có thể xác định vị trí trang web của framework đó. Từ đó, chúng ta có thể tìm hiểu thêm về phần mềm và các thông tin khác, có thể dẫn đến việc khám phá thêm nhiều nội dung khác.

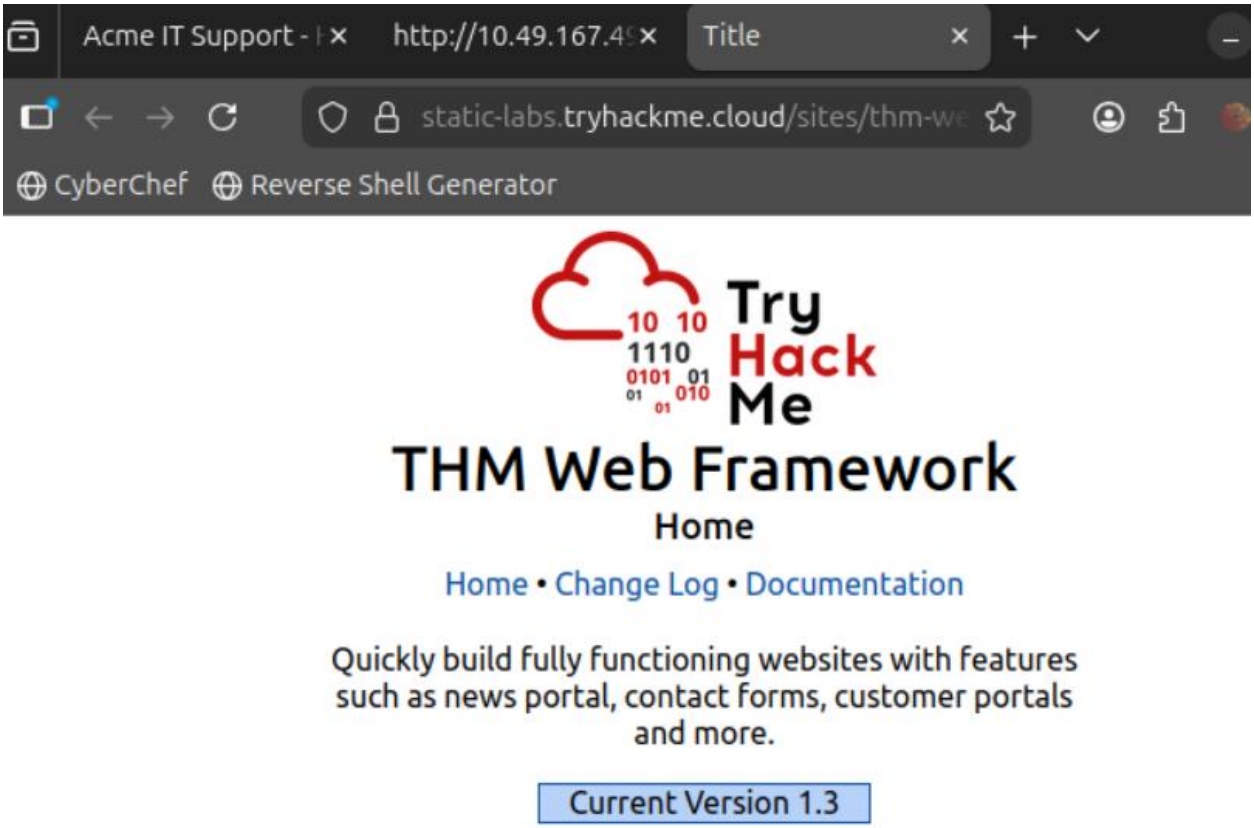
Chúng ta cùng xem mã nguồn của trang Acme IT Support.



Chúng ta thấy một bình luận tải trang và liên kết đến trang web đó:

```
33                  </ul>
34              </div><!--/.nav-collapse -->
35          </div>
36      </nav><div class="container" style="padding-top:60px">
37      <h1 class="text-center">Acme IT Support</h1>
38      <div class="row">
39          <div class="col-md-8 col-md-offset-2 text-center">
40              <img src="/assets/staff.png">
41              <p class="welcome-msg">Our dedicated staff are ready <a href="/secret-page">to</a>
42          </div>
43      </div>
44 </div>
45 <script src="/assets/jquery.min.js"></script>
46 <script src="/assets/bootstrap.min.js"></script>
47 <script src="/assets/site.js"></script>
48 </body>
49 </html>
50 <!--
51 Page Generated in 0.03622 Seconds using the THM Framework v1.2 ( https://static-labs.tryhackme.
```

Chúng ta thử truy cập theo đường link đó.



Click vào phần “Document”.

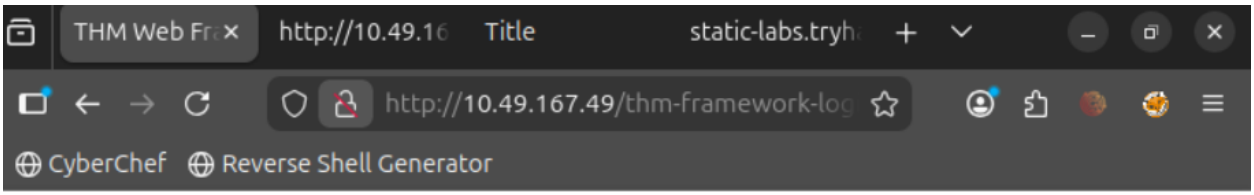
Documentation

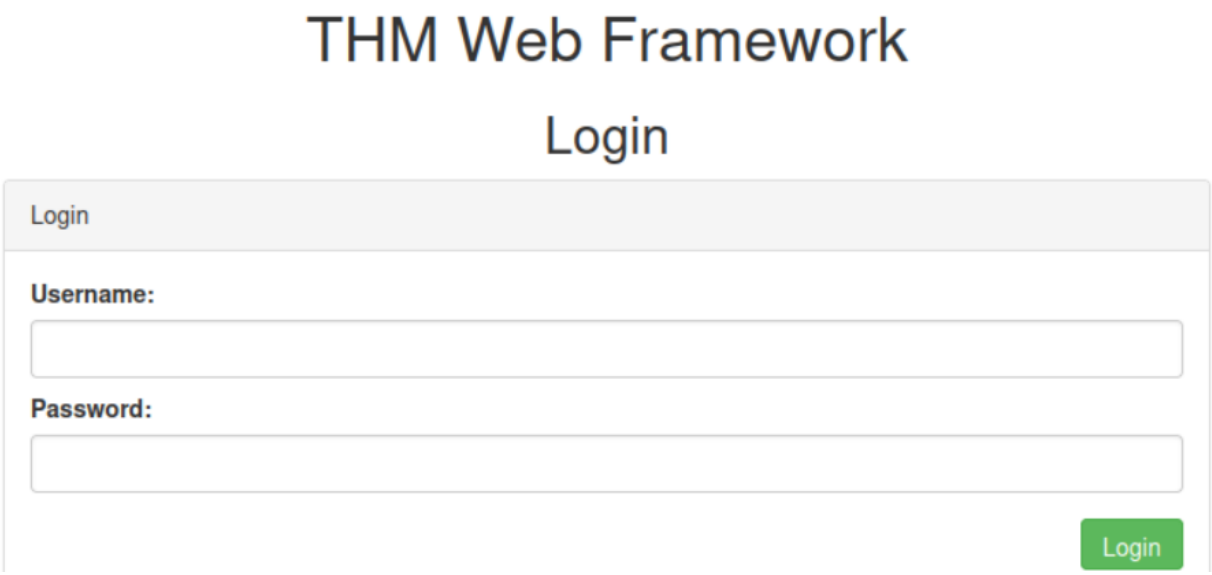
The documentation for the framework is pre-installed on your websites administration portal.

Once you've installed the framework navigate to the **/thm-framework-login** path on your website.

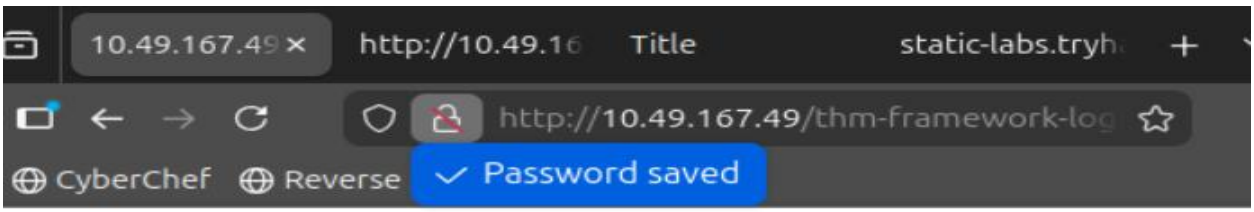
You can login with the username **admin** and password **admin** (make sure you change this password)

Ta truy cập theo đường dẫn "/thm-framework-login" trên trang Acme IT Support và đăng nhập bằng tài khoản admin và mật khẩu admin.





Ta tìm được flag



THM{CHANGE_DEFAULT_CREDENTIALS}

What is the flag from the framework's administration portal?

THM{CHANGE_DEFAULT_CREDENTIALS} ✓ Correct Answer

6. OSINT – Google Hacking/Dorking

Các nguồn tài nguyên bên ngoài có sẵn có thể giúp khám phá thông tin về trang web mục tiêu của chúng ta; những nguồn tài nguyên này thường được gọi là OSINT (Open Source Intelligence) vì chúng là các công cụ thu thập thông tin miễn phí:

Google Hacking/Dorking

- Kỹ thuật Google hacking/Dorking tận dụng các tính năng tìm kiếm nâng cao của Google, cho phép chúng ta chọn lọc nội dung tùy chỉnh. Ví dụ, chúng ta có thể chọn kết quả từ một tên miền nhất định bằng cách sử dụng bộ lọc site:, chẳng hạn như (site:tryhackme.com). Sau đó, ta có thể kết hợp điều này với các cụm từ tìm kiếm nhất định, ví dụ như từ "admin" (site:tryhackme.com admin). Điều này sẽ chỉ trả về kết quả từ trang web tryhackme.com có chứa từ "admin" trong nội dung của nó. Ta cũng có thể kết hợp nhiều bộ lọc. Dưới đây là một ví dụ về các bộ lọc khác mà chúng ta có thể sử dụng:

Filter	Example	Description
site	site:tryhackme.com	Trả về các kết quả chỉ từ địa chỉ website được chỉ định
inurl	inurl:admin	Trả về các kết quả có chứa từ được chỉ định trong URL
filetype	filetype:pdf	Trả về các kết quả là những tệp có phần mở rộng được chỉ định
intitle	intitle:admin	Trả về các kết quả có chứa từ được chỉ định trong tiêu đề trang

What Google dork operator can be used to only show results from a particular site?

site: ✓ Correct Answer

7. OSINT – Wappalyzer

Wappalyzer

- Wappalyzer (https://www.wappalyzer.com/) là một công cụ trực tuyến và tiện ích mở rộng trình duyệt giúp xác định các công nghệ mà một trang web sử dụng, chẳng hạn như framework, Hệ thống quản lý nội dung (CMS), bộ xử lý thanh toán và nhiều hơn nữa, thậm chí nó còn có thể tìm ra cả số phiên bản.

What online tool can be used to identify what technologies a website is running?

Wappalyzer ✓ Correct Answer

8. OSINT – Wayback Machine

Wayback Machine

- Wayback Machine (https://archive.org/web/) là một kho lưu trữ lịch sử các trang web có từ cuối những năm 90. Chúng ta có thể tìm kiếm tên miền, và nó sẽ hiển thị cho chúng ta tất cả các lần dịch vụ này đã thu thập dữ liệu từ trang web và lưu nội dung. Dịch vụ này có thể giúp tìm ra những trang cũ có thể vẫn còn hoạt động trên trang web hiện tại.

What is the website address for the Wayback Machine?

https://archive.org/web/ ✓ Correct Answer

9. OSINT – Github

Github

- Để hiểu về GitHub, trước tiên chúng ta cần hiểu về Git. Git là một hệ thống kiểm soát phiên bản theo dõi các thay đổi đối với các tệp trong một dự án. Làm việc nhóm trở nên dễ dàng hơn vì bạn có thể thấy mỗi thành viên trong nhóm đang chỉnh sửa gì và những thay đổi họ đã thực hiện đối với các tệp. Khi người dùng hoàn thành việc thay đổi, họ sẽ cam kết các thay đổi đó kèm theo thông báo và sau đó đẩy chúng trở lại vị trí trung tâm (kho lưu trữ) để những người dùng khác có thể tải các thay đổi đó về máy tính cục bộ của họ. GitHub là phiên bản Git được lưu trữ trên internet. Các kho lưu trữ có thể được thiết lập ở chế độ công khai hoặc riêng tư và có nhiều quyền truy cập khác nhau. Bạn có thể sử dụng tính năng tìm kiếm của GitHub để tìm kiếm tên công ty hoặc tên trang web nhằm xác định vị trí các kho lưu trữ thuộc về mục tiêu của bạn. Sau khi tìm thấy, ta có thể có quyền truy cập vào mã nguồn, mật khẩu hoặc nội dung khác mà chúng ta chưa tìm thấy.

What is Git?

version control system ✓ Correct Answer

10. OSINT – S3 Buckets

S3 Buckets

- S3 Buckets là dịch vụ lưu trữ do Amazon AWS cung cấp, cho phép người dùng lưu trữ các tệp và thậm chí cả nội dung tĩnh của trang web trên đám mây, có thể truy cập qua HTTP và HTTPS. Chủ sở hữu tệp có thể thiết lập quyền truy cập để cho phép công khai, riêng tư hoặc thậm chí ghi tệp. Đôi khi, các quyền truy cập này được thiết lập không chính xác và vô tình cho phép truy cập vào các tệp không nên được công khai. Định dạng của S3 buckets là http(s)://{name}.s3.amazonaws.com, trong đó {name} do chủ sở hữu quyết định, ví dụ như tryhackme-assets.s3.amazonaws.com.

What URL format do Amazon S3 buckets end in?

.s3.amazonaws.com ✓ Correct Answer

11. Automated – Discovery

Automated Discovery

- Khám phá tự động là quá trình sử dụng các công cụ để tìm kiếm nội dung thay vì thực hiện thủ công. Quá trình này được tự động hóa vì nó thường bao gồm hàng trăm, hàng nghìn hoặc thậm chí hàng triệu yêu cầu đến máy chủ web. Các yêu cầu này kiểm tra xem một tệp hoặc thư mục có tồn tại trên trang web hay không, cho phép chúng ta truy cập vào các tài nguyên mà trước đây chúng ta không biết đến. Quá trình này được thực hiện nhờ sử dụng một tài nguyên gọi là danh sách từ (wordlists).

Wordlists

- Danh sách từ vựng chỉ đơn giản là các tệp văn bản chứa một danh sách dài các từ thường dùng; chúng có thể phục vụ nhiều trường hợp sử dụng khác nhau. Ví dụ, một danh sách từ vựng mật khẩu sẽ bao gồm các mật khẩu được sử dụng thường xuyên nhất, trong khi trường hợp của chúng ta là tìm kiếm nội dung, vì vậy chúng ta cần một danh sách chứa các tên thư mục và tệp được sử dụng thường xuyên nhất.

Automation Tools

- Mặc dù có rất nhiều công cụ phát hiện nội dung khác nhau, mỗi công cụ đều có những tính năng và nhược điểm riêng, chúng ta sẽ xem xét ba công cụ được cài đặt sẵn trên máy chủ tấn công của mình: ffuf, dirb và gobuster.

1. Using gobuster:

```
root@ip-10-49-120-217:~# gobuster dir --url http://10.49.167.49/ -w /usr
/share/wordlists/SecLists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.167.49/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/SecLists/Discovery/Web
-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/assets               (Status: 301) [Size: 178]

/contact              (Status: 200) [Size: 3108]
/customers            (Status: 302) [Size: 0]
/development.log      (Status: 200) [Size: 27]
/monthly              (Status: 200) [Size: 28]
/news                 (Status: 200) [Size: 2538]
/private              (Status: 301) [Size: 178]

/robots.txt           (Status: 200) [Size: 46]
/sitemap.xml          (Status: 200) [Size: 1383]
Progress: 4655 / 4656 (99.98%)
```

What is the name of the directory beginning "/mo...." that was discovered?

/monthly

✓ Correct Answer